Sentinel — AI Product Review Board

A three-model, $100M due-diligence review of product, market, architecture, security, and company case.

Board: Claude Opus 4.8 (Anthropic) · OpenAI Codex (GPT-5.6-sol) · Antigravity / Gemini 3.1 Pro (Google) — three independent models from rival vendors, acting as CTOs, founders, product strategists, Tier-1 investors, security architects, UX leads, and enterprise buyers. **Method:** three adversarial rounds — independent dossiers → cross-examination → final verdict — over the live repository. **Date:** 23 July 2026.

> ***Verdict in one line.*** *The board unanimously declines to fund Sentinel as an AI-security detection product at any priced round today, but sees a genuine, potentially category-defining company hiding inside it — a* ***vendor-neutral, cryptographically portable agent-evidence and policy layer*** *— reachable only after the current pass's critical defects and one more relocation of the same failure class are fixed.*

Contents

Sentinel — AI Product Review Board

1. Executive Summary

2. Independent Reviews

3. Complete Debate Transcript

4. Component-by-Component Review

5. Market Intelligence Report

6. Competitor Analysis

7. Gap Analysis

8. Startup Strategy

9. Investment Review

10. Business Model

11. Technical Architecture Review

12. Security Audit

13. Performance Audit

14. AI Capability Audit

15. UX Review

16. Feature Discovery

17. Hidden Opportunities

18. Patent-Worthy Ideas

19. Launch Readiness Checklist

20. Risk Register

21. Prioritized Improvement Backlog

22. Multi-Year Product Roadmap

23. Final Council Consensus

24. Actionable Next Steps

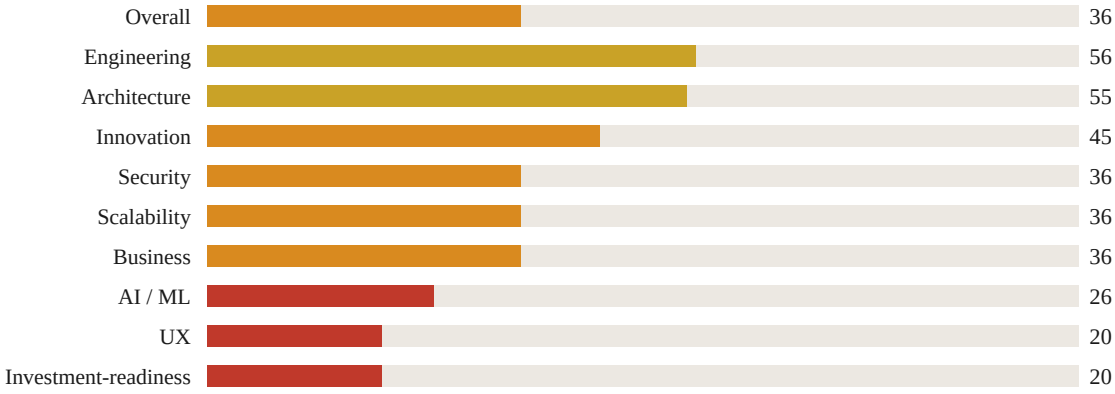
1. Executive Summary

Sentinel is a pre-production "Trust & Incident Attestation" layer for AI agents: it ingests signed agent runtime events, evaluates them against a configurable policy, escalates proposed responses to a human, and can anchor incident evidence to a blockchain. It is honest about its pre-production status in its own README, and it carries an unusual asset — a team that, across five hard review passes, learned to make several failure classes fail CI.

The board reviewed it as if deciding on a $100M investment. It did not find a fundable detection product. It found a **disciplined engineering substrate wrapped around a detector that is honestly disclosed as non-viable and a "moat" that does not yet hold.** All three seats converged, from independent starts, on the same load-bearing facts.

The consensus scorecard

Consensus Scores (mean of three independent models, 0-100)



What the board agreed on

- **The failure class relocated a fifth time.** V5's stated goal was to make failure classes *structurally impossible*. Instead, the retry/DLQ guarantee is dead end-to-end: `process()` swallows every stage exception, calls `repository.fail()`, and returns normally (`api/pipeline.py:214-217`), so the worker reaches `INCIDENT_QUEUE.complete(task)` (`api/main.py:147`) and never retries. A transient model/provider outage — the only failure a live system actually produces — silently and permanently terminates an incident.
- **The proposed moat is broken two independent ways.** (a) Codex constructed a *forged* evidence package that `verify_package()` certifies `True`: offline verification proves self-consistency, not provenance, because an unanchored package supplies its own root (`app/attestation/ledger.py:159-213`). (b) The ledger/attestation writes are non-idempotent and happen *before* the fence with no lease epoch passed into the pipeline (`api/pipeline.py:162,199`; `api/main.py:146`), so lease loss duplicates the tamper-evident record.
- **The detector is unusable and honestly says so.** Cross-source AUC 0.763 is the mean of only two mixed-class folds (n=2); expected calibration error is 0.48; reproduced fold FPRs range 6% -> 73%, with 94.7% FNR on one multilingual set. No operational threshold exists.
- **Two customer-facing paths are simply broken.** Every analyst *reject* returns HTTP 500 (`api/main.py:861`), and the dashboard renders the attacker's own payload as live HTML via `innerHTML` (`dashboard/index.html:1090`) — stored XSS in a security tool, sourced from the exact injection strings it exists to catch.

- **The real company is a pivot.** Discard proprietary detection; become the neutral, standardized, cryptographically verifiable **evidence-and-policy interchange layer** — "OpenTelemetry for agent accountability" — that every agent runtime and every consolidating incumbent writes to. Target the buyers stranded by ~$29B of 2025-26 M&A.

SWOT at a glance

Sentinel SWOT (board consensus)

Strengths	Weaknesses
• Rare correction discipline - five review passes; some failure classes now fail CI • Genuinely strong primitives: transactional-outbox queue, fenced leases, signed agent identity • Institutional honesty - README/ADVERSARIAL_REVIEW name unfixed classes and retract a metric	• Detector unusable - n=2 AUC 0.763, ECE 0.48; no operational threshold • Shipping-code defects: DLQ bypass, stored XSS, reject-500, forgeable evidence package • No customers, no wedge in shipping code, demo-grade UI, manual SDK instrumentation
Opportunities	**Threats**
• ~$29B market consolidation strands focused-tool buyers who want a neutral layer • EU AI Act Article 50 (Aug 2026) + demand for portable machine-verifiable attestation • "OTel for agent accountability" - an open evidence/identity standard others adopt	• Platform giants (Microsoft Agent 365, Palo Alto, Cisco, Check Point, SentinelOne) bundle and distribute • A sixth relocation of the same failure class; correctness theater outpacing enforcement • Immutable storage of unredacted attacker payloads -> GDPR / CSAM compliance liability

The recommendation

Do not launch. Do not raise a priced round. Spend 30 days killing the guaranteed failures (DLQ bypass, XSS, reject-500), 90 days re-anchoring the evidence moat with authenticated provenance and shipping OTel auto-instrumentation, and the following two quarters proving the neutral-evidence wedge with 3-5 paid design partners drawn from the stranded-buyer cohort. The only rational instrument today is a small, note-only **team bet**, not a product bet.

2. Independent Reviews

In Round 1 each model reviewed the repository alone, with no visibility into the others. The convergence below is therefore signal, not groupthink.

Claude Opus 4.8 — "engineering integrity is not a product"

Thesis: no priced round; a founder/acqui-hire bet on engineering discipline is the only defensible check. Identified the transactional outbox, fenced leases, signed agent identity, and offline-verifiable Merkle evidence as genuinely strong, and named the ledger-head fork race, unwired OIDC, the supervisor injection-guard gap, app-only tenancy, and per-worker rate limiting as the core weaknesses. Round-1 scores: Engineering 76, Architecture 71, Security 57, AI 38, UX 33, Business 19, Investment 22.

OpenAI Codex (GPT-5.6-sol) — "a security prototype, not a company"

Harshest of the three. Reproduced the detection metrics directly (AUC 0.7626, ECE 0.4836). Surfaced concrete shipping defects the others missed on first pass: the retry/DLQ bypass end-to-end, stored XSS in the dashboard, and the broken reject route (500). Strong market intelligence citing Microsoft Agent 365, Zenity, and the acquired incumbents. Round-1 scores: Engineering 58, Architecture 51, Security 38, AI 27, UX 18, Business 24, Investment 16.

Antigravity / Gemini 3.1 Pro — "fund the plumbing, not the guardrail"

Credited the structural-test enforcement and atomic queue handoffs, but judged the detector "fundamentally broken for enterprise use." Uniquely flagged a fatal compliance hazard — immutable, unredacted storage of attacker payloads creating GDPR "right to be forgotten" and CSAM liabilities. Most bullish on the business pivot (stranded-buyer wedge). Round-1 scores: Engineering 75, Architecture 65, Security 60, AI 25, UX 40, Business 20, Investment 15.

Where they agreed before they ever spoke

All three, independently: **do not fund the detection product; the wedge is portable neutral evidence; the blockchain/testnet is not the moat; detection cannot be thresholded (ECE 0.48); no RLS is a critical enterprise blocker; the structural tests are partly theatre; the market has consolidated and the opening is the stranded cohort.**

3. Complete Debate Transcript

Round 2 was open cross-examination; Round 3 forced final positions and dissents. The debate materially changed conclusions — this is not three models restating openings.

The decisive Round-2 exchanges

- **Codex vs. Claude on the moat.** Claude (R1) called offline-verifiable evidence "the strongest real artifact in the repo." Codex refuted it live: it built a one-leaf package with fabricated evidence and a matching fabricated root, and `verify_package()` returned `True` (`app/attestation/ledger.py:159-213`). "VERIFIED" means *mathematically self-consistent*, not *this evidence came from Sentinel at the claimed time*. This is the single result that most changed the investment decision — it moved portable evidence from "earned wedge" to "promising data structure, not yet a trust system."
- **Claude concedes relocation #5.** As the seat that implemented the V5 remediations, Claude confirmed Codex's DLQ-bypass finding against its own work: the DLQ is unreachable for pipeline failures, so "the failure was hardened at the queue layer while the caller was rewired to never invoke it." It also conceded that the two headline "structural" tests are substring checks (`tests/test_failure_classes_are_structural.py:250-264`) — a comment containing the token passes.
- **Codex corrects Antigravity twice, precisely.** ECE 0.48 "is not a 48% error rate" — it measures probability-frequency mismatch, so the correct conclusion is "cannot support thresholds," not "48% wrong." And "no RLS guarantees a leak" is overstated: current reads consistently include the tenant predicate; the risk is that one *future* missing predicate has no database backstop.
- **Both reject "move Sepolia to mainnet."** Antigravity proposed mainnet as the fix; Claude and Codex agreed this "industrializes the wrong architecture." The correct design is customer-controlled storage plus periodic signed/Merkle root commitments — mainnet is optional timestamping, not the evidence system.
- **What all three missed until late:** the `protect_evaluate` endpoint that the deck sells as the "protect mode next" narrative persists nothing and was `NameError`-broken until this pass (`api/main.py:720-751`) — a second, independent relocation of the undefined-name class sitting under the exact feature investors are told to reward.

Round-3 dissents

- **Claude** dissents from Antigravity's Engineering 75 as internally inconsistent ("you cannot warn the tests enforce the wrong constraint and then bank a score that rests on them") and from crediting the ledger as an existing moat.
- **Codex** dissents from Antigravity's Business 60 and from calling the evidence ledger a *current* moat: "consolidation creates an opening, not product-market fit," and stranded buyers "will reject a vendor whose first pentest finds stored XSS."
- **Antigravity** dissents from Claude and Codex's "entirely unfundable": it argues the plumbing (durable outbox, signed identity, offline ledger) is *highly* fundable as a vendor-agnostic audit layer for stranded buyers, if stripped of the detection pretence.

The disagreements narrowed to one axis: **is the neutral-evidence wedge fundable *today* (Antigravity: yes, as a pivot) or only after the critical defects close (Claude, Codex: only then).** All three agree on the destination.

4. Component-by-Component Review

Each component was contested across rounds; the resolved position is shown with severity.

Component	Strongest claim	Board's resolved position	Severity
Lifecycle / queue / DLQ	"Failure classes are now structurally impossible"	Atomic acceptance + fenced completion are real, but the DLQ is unreachable end-to-end and side effects are unfenced -- relocation #5	**Critical**
Attestation / ledger (the moat)	"Offline Merkle inclusion is a legitimate portability feature"	Concept is real; verifier authenticates self-consistency not provenance, and append races + writes non-idempotently outside the fence	**Critical**
Detection / evaluation	"Honestly retracted, cross-source AUC 0.763"	Directionally honest but n=2 and ECE 0.48 -> no operational threshold; not a security boundary	**Critical**
Auth / RBAC / tenancy	"OIDC implemented; SSO supported"	OIDC verifies JWTs but is wired to no route; RBAC is API-key only; app-only tenancy with no RLS backstop; raw keys despite "stored as hashes" claim	**Critical**
Agent orchestration / prompt safety	"Fenced payloads + marker escalation"	Mandatory `gpt-4o` per incident sets priority/mitigation; supervisor omits the standing injection guard; regex escalation is evadable	**High**
Structural tests / CI	"13 classes enforced by tests, not review"	Mixed: some are real AST/behavioral guards; the two load-bearing ones are substring checks; dependency audit is non-blocking	**High**
SDK / API / dashboard	"Attractive demo shell"	Unauthenticated fetches, manual per-call instrumentation, stored XSS on ingested payload, reject-500 -- not a working authenticated SOC journey	**Critical**

5. Market Intelligence Report

The category exists and has already consolidated. Enterprise spend on agentic AI is projected at ~$201.9B for 2026; around RSAC 2026, ~$392M in agentic-AI-security funding was announced inside a two-week window, and roughly **$29B of M&A** has been assembled into platform stacks purpose-built to discover, govern, and secure AI agents.

- **Acquired and absorbed:** Lakera -> Check Point (~$300M); Protect AI -> Palo Alto Networks; Prompt Security -> SentinelOne; Aim Security -> Cato Networks; Astrix (non-human identity) -> Cisco (~$400M).
- **Still independent:** Zenity, Noma Security ($100M Series B), WitnessAI, HiddenLayer, Straiker, Guardion, Pillar, Lasso.
- **Platform giants competing directly:** Microsoft (Agent 365 bundles inventory, identity, DLP, audit, detection, real-time blocking — a distribution monster), Cisco, Palo Alto, Check Point, SentinelOne, Radware.

What investors funded in 2026 is precisely the "see/test/constrain/audit agents *before* they create risk" framing — runtime controls, observability, and evaluation. Sentinel's stated "observe now, protect next" posture is exactly this framing; the board's question was whether the code earns it. It does not yet. Pricing across the category is almost universally quote-based (Lakera Guard's free developer tier is the notable exception), so there is no per-agent or per-event list price to anchor against — an opening for a transparent, self-hostable challenger.

The clearest opening: every acquisition strands a cohort of buyers who chose a focused tool and inherited a platform roadmap. Those buyers want a neutral, non-platform layer they control. That is the wedge — if a product can survive their diligence.

6. Competitor Analysis

Where Sentinel stands vs the field (borrow / never-copy)

Strengths
• Self-hostable and inspectable - most incumbents are closed SaaS
• Vendor-neutral evidence portability - incumbents trap audit logs in their platform

Weaknesses
• Worse on discovery, integrations, posture, DLP, enforcement, UX, threat research, distribution

Opportunities
• Borrow - OTel schemas, agent/MCP inventory, graph blast-radius analysis, inline policy points
• Never copy - platform-suite breadth; "blockchain security"; per-event on-chain writes

Threats
• Microsoft/Palo Alto/Cisco/Check Point/SentinelOne own distribution and compliance certs

Capability	Sentinel today	Incumbent platforms
Runtime guardrails on prod traffic	No (observe only; protect is a stub)	Yes -- mature, on real traffic
Trained detector	No -- n=2 AUC, ECE 0.48	Yes -- production detectors + threat research
Agent / MCP discovery & inventory	No	Yes
Identity / posture / DLP	Partial (signed identity only)	Yes
SSO / SCIM / RLS	OIDC dead-code; no SCIM; no RLS	Yes
Distribution & compliance certs	None	Yes (SOC2/ISO, channel, bundling)
Self-hostable, inspectable	**Yes**	Mostly no
Vendor-neutral portable evidence	**Concept only (unauthenticated)**	No -- logs locked to platform

The honest competitive position for a small team is not "compete on breadth" and not "be acquired into another platform" — it is **serve the segment the giants structurally cannot: buyers who want a neutral layer they own precisely because it competes with none of them.**

7. Gap Analysis

Real, unsolved market pains and whether Sentinel can credibly close them:

Market pain	Can Sentinel close it?	Basis
Portable, tamper-evident agent audit trails that survive vendor churn	Yes -- with work	The offline ledger addresses this once provenance is authenticated
Low-friction capture of agent behavior	No, today	Manual per-call SDK instrumentation is the biggest adoption tax
Tunable, trustworthy detection	No	ECE 0.48 -> no defensible threshold
Enforcement without breaking agents (observe -> protect)	No, today	Protect Mode is a stateless allow/deny stub
Shadow-agent discovery, delegated identity, tool least-privilege	No	Not implemented
Cross-agent cascade / correlated multi-step attacks (ASI08)	No	No graph correlation
Data residency + evidence export during vendor migration	Yes -- with work	Directly aligned with the wedge
EU AI Act Article 50 (chatbot disclosure, content marking)	No	Not implemented; regulation creates urgency, not PMF

The governance gap is real (41-44% of orgs have no human-in-the-loop; 55-63% no purpose binding or kill switch). Sentinel addresses only tamper-evident evidence and rudimentary tool telemetry credibly. The unclosed gaps are the roadmap.

8. Startup Strategy

The board's strategic recommendation is a **hard pivot**: stop being "an AI detector plus blockchain," become a vendor-neutral, self-hostable agent **evidence, identity, and policy-portability layer.**

- **MVP (now -> 90 days):** fix the critical defects; ship OTel/MCP auto-capture; authenticated provenance ledger; run 3 unpaid design partners on real agent traffic in observe-only mode.
- **V1 (6-12 months):** self-hosted evidence + policy portability with customer-held trust roots; SIEM/SOAR + IdP integrations; agent inventory; purpose binding; compliance exports; deterministic policy authoritative, detector demoted to optional second opinion.
- **V2 (12-24 months):** inline enforcement with counterfactual policy replay; graph correlation for cascade containment; DLP/classification; identity lifecycle.
- **V3 (24-36 months):** the open evidence/identity interchange standard + a policy/verifier marketplace; privacy-preserving cross-customer threat intelligence.

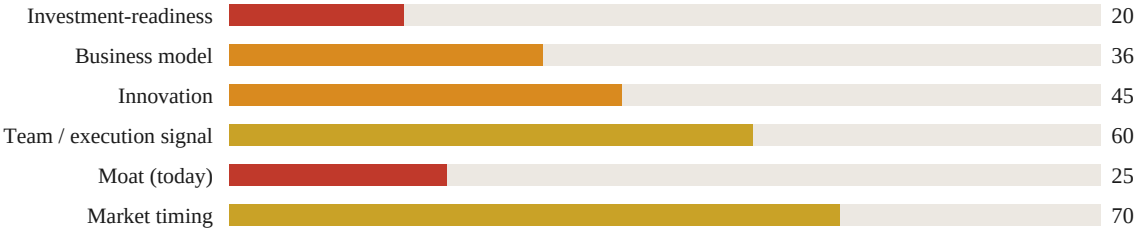
Initial ICP: regulated mid-market, sovereign/on-prem deployments, and the post-acquisition stranded cohort — buyers who refuse to surrender their logs to a consolidated platform.

9. Investment Review

Simulating the diligence of YC, Sequoia, a16z, Accel, Lightspeed, and Benchmark:

- **Would they invest today?** No priced round. A top seed fund might write a small, note-only check on *exceptional founders with design partners*; none would lead a Series A on this evidence. YC-style programs might admit the team for the correction discipline and the wedge thesis.
- **Why not.** Zero production traffic, zero customers, an uncalibrated detector, an unauthenticated "moat," and shipping code that fails its own first pentest (reject-500, XSS on ingested payloads). The stranded buyers who are the wedge are *unusually demanding* and will run exactly this diligence.
- **What must improve to earn a check.** Close the Criticals; re-anchor provenance with customer-held keys; ship auto-instrumentation; sign 3-5 paid design partners; produce per-tenant precision/recall at real base rates; external cryptographic review.

Investment-lens scores (consensus, 0-100)



Consensus investment score: 20/100 today — with a credible path to a fundable seed profile in ~2 quarters of focused work, and a genuine (if low-probability) path to a category-defining outcome over 24-36 months. The one number that is high — market timing — is why the team bet is rational at all.

10. Business Model

The board (led by Codex's packaging, refined by Antigravity's free-tier point) recommends usage-metered tiers, never pricing per agent alone (agent identity is fluid):

Tier	Price	Includes
Developer	Free	1 agent / 100k events, local evidence verifier (drives bottoms-up adoption)
Team	$1k-$3k / mo	10-25 agents, hosted control plane, 30-day retention
Enterprise	$50k-$150k / yr platform + event volume	Private cloud, RLS, SSO, regional retention, SIEM/SOAR, premium support
Regulated / Sovereign	$150k-$500k / yr	Self-hosted license with escrow + verifier tooling

Meter high-cost AI investigations separately. **Growth loop:** open-source the evidence verifier + schema to make Sentinel the neutral verification default; monetize issuance, retention, enforcement, and portability. **Network effect:** more runtimes and policy authors improve interoperability; auditors and insurers begin accepting Sentinel evidence packages; privacy-preserving incident intelligence improves detection for all. Paid design-partner pilots at $25k-$75k are the near-term proof instrument.

11. Technical Architecture Review

The substrate is genuinely well-built; the failures are at the boundaries and in the end-to-end wiring.

Strengths (with citations)

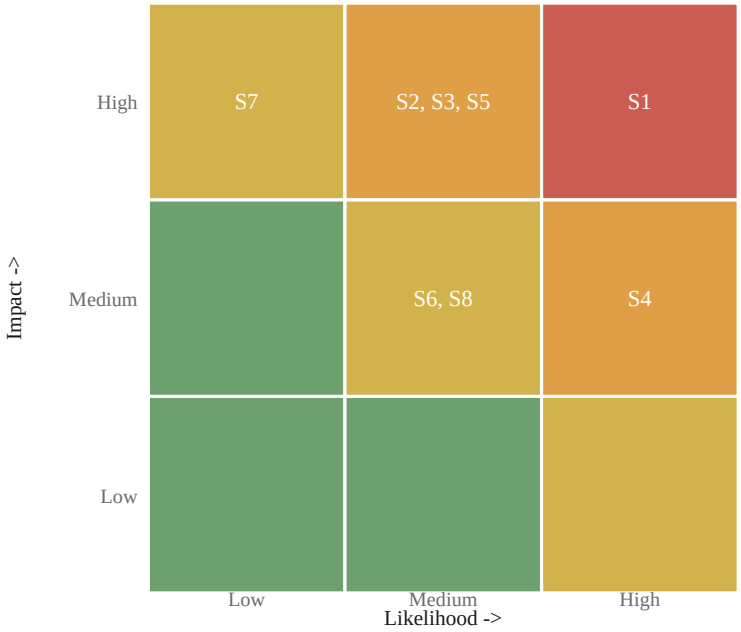
- **Transactional outbox.** `DurableQueue.accept()` writes incident + queue row in one `begin_immediate()` transaction (`app/queue/durable_queue.py:141-163`); the API answers `processing: true` only after commit.
- **Fenced leases.** Monotonic `lease_epoch`; completion conditional on `(claimed_by, lease_epoch)`, `LeaseLost` on zero rows (`durable_queue.py:246-264`) — a stale worker cannot corrupt a reclaimer's queue write.
- **Single-authority state machine.** Fixed transitions + durable-artifact prerequisites checked inside the repository transaction (`app/core/lifecycle.py:67-112`; `app/core/repository.py:224-264`).
- **Signed agent identity.** secp256k1 keypair, `agent_id` = derived address, canonical signature per event (`sentinel_sdk/client.py:55-67`); unsigned clients explicitly downgraded.

Architectural defects

- **DLQ unreachable end-to-end** (`api/pipeline.py:214-217` -> `api/main.py:147`) — the fence protects the queue row only; the epoch never reaches pipeline writes.
- **Ledger head read-then-append is non-atomic** (`app/attestation/ledger.py:48-54`) with no `UNIQUE(tenant_id, prev_chain_hash)` — concurrent replicas fork the chain.
- **App-only tenancy** — correctness depends on every query carrying `WHERE tenant_id=?` with no Postgres RLS backstop.
- **Per-worker in-memory rate limiting** (`api/rbac.py:141`) — limits multiply across replicas.
- **Mandatory** `gpt-4o` **per incident** in the control path (`agents/supervisor_agent.py:16`).

12. Security Audit

Security Risk Heatmap (Likelihood x Impact)



S1	Stored XSS renders attacker payload as live HTML
S2	Forgeable VERIFIED evidence package (no external root)
S3	App-only tenancy, no RLS backstop
S4	OIDC wired to nothing (SSO is dead code)
S5	Immutable unredacted attacker payloads (GDPR/CSAM)
S6	Supervisor lacks standing injection guard
S7	Unaudited ECDSA recovery primitive
S8	CI dependency audit non-blocking

- **OWASP Agentic ASI coverage:** the default policy nominally maps ~5 of 10 (ASI01/02/03/05/09); ASI04/06/07/08/10 lack real coverage — no supply-chain scanning, memory provenance, authenticated inter-agent protocol, cascade analysis, or rogue-agent model.
- **Stored XSS (S1):** `dashboard/index.html:1090` interpolates `raw_payload.content` — the attacker's injection string — into `innerHTML`, executing it in the analyst's browser. Fix: `textContent` + strict CSP.
- **Trust-model failure (S2):** `verify_package()` authenticates an in-package root; a fabricated package returns `True`. Fix: signed batch manifests + customer-held keys + independently published roots.
- **Compliance hazard (S5, Gemini's unique find):** append-only immutable storage of unredacted attacker payloads collides with GDPR "right to be forgotten" and CSAM handling. Fix: pre-ledger redaction + a cryptographically sound tombstone pattern.
- **Secrets:** raw API keys live in the in-process config map despite a "stored only as hashes" docstring (`api/auth.py:13` vs `:96`). Encryption-at-rest, KMS rotation, DSAR workflows, and audited recovery are unverified.

Positives: fail-closed, constant-time API-key auth; duplicate key material aborts startup; human-approval + HMAC-bound webhook receipts for remediation.

13. Performance Audit

Bottleneck	Evidence	Ceiling
One `gpt-4o` triage call per incident	`agents/supervisor_agent.py:16`	Dominant cost/latency; a DoS/cost-amplification vector under per-worker limits
50ms transactional queue polling, no batching	`app/queue/durable_queue.py:309-320`	Throughput bound; no partitioning
Ledger head serialization + fork risk under replicas	`app/attestation/ledger.py:48-54`	Write contention at volume
Per-worker in-memory rate limits	`api/rbac.py:141`	Effective limits drift x replicas
High-cardinality `tenant_id` Prometheus labels	`app/observability/telemetry.py:42-49`	Metric-store blowup at scale
No streaming/batching of LLM triage	—	Throughput = OpenAI latency x concurrency

Pilot scale (Postgres) is fine. For millions of events: separate append-only ingest from incident workflow, batch evaluation, partition by tenant/time, add event streaming with explicit replay semantics, globally replicated object evidence, and regional control planes. A cache is unnecessary for incident truth today; it becomes useful for JWKS, policy artifacts, and threat-intel responses.

14. AI Capability Audit

- **Detection is not a security boundary.** Cross-source AUC 0.763 is the mean of only two mixed-class folds (only 2 of 6 sources contain both classes); reproduced ECE 0.4836; fold FPRs 6.1% -> 73%; 94.7% FNR on MultiJail; multilingual benign FPR ~51%. The confidence score cannot set an operational threshold.
- **Honesty is real.** The code rejects pooled AUC as invalid and the README discloses the two-fold limitation; the earlier 0.855 figure was retracted as dataset-provenance leakage. Diligence-positive, but it does not make an uncalibrated detector fundable.
- **The "semantic features" are curated keyword lists + logistic regression** (`app/detection/semantic_features.py`) — a reasonable weak second opinion, not robust to obfuscation; multilingual explicitly unvalidated.
- **Orchestration is thin.** Mandatory `gpt-4o` (no model/version receipts, budgets, timeouts, or deterministic fallback); investigation is one tool-call round then synthesis; no durable memory, cross-incident learning, or genuine multi-agent collaboration — sequential calls that also usefully contain autonomy risk.
- **Reproducibility gap.** The benchmark requires network at runtime (HuggingFace datasets-server), cache uncommitted — so the headline figure is not offline-reproducible from the repo alone.

Recommendation: demote detection to an optional shadow signal; make deterministic policy authoritative; support bring-your-own-detector; collect design-partner traffic and evaluate precision-recall at real base rates by tenant/language/attack family.

15. UX Review

The user journey is developer-centric and, in two places, broken.

- **Landing / onboarding:** no product landing; README-driven; config-file API keys, no self-serve.
- **Adoption tax:** a developer must generate a key, enroll the address, and **hand-instrument every tool call** (`sentinel_sdk/client.py:165`) — the single biggest barrier.
- **Dashboard:** one 53KB static `index.html` — no case management, no RBAC UI, tenants invisible; it fetches protected endpoints **without credentials**, so metrics/incidents fail under correct auth; errors go to `console`/`alert()`.
- **Broken paths:** every analyst **reject returns 500** (`api/main.py:861`); the dashboard renders ingested attacker payload as live HTML (stored XSS).
- **First-run cliff:** the pilot doc instructs `SENTINEL_API_KEY=dev_test_key`, which live mode then rejects (`config.py`).
- **Framing:** a testnet-first (Base Sepolia) header makes the product read as hackathon-grade to an enterprise buyer.

Fix priority: build an authenticated SPA with an approval/case workflow (approvals are the core safety gate yet absent from the UI), text-safe rendering + CSP, and OTel/framework auto-capture to remove the instrumentation wall.

16. Feature Discovery

Non-obvious features the board would build — "the product customers never knew they needed."

#	Feature	Problem solved	AI need	Defensibility
1	Evidence escrow / audit-log portability	Acquisition-stranded buyers can't get clean, verifiable logs out of a platform	None (that's the point)	Becoming the neutral verification standard
2	Federated injection-attempt threat feed	Every deployment sees novel injections; none share them	Dedup/clustering	Data network effect -- the one durable detection moat
3	Counterfactual policy replay ("what-if")	SOCs fear FPR before enabling Protect Mode	Optional rule synthesis (never authoritative)	Customers accumulate labeled policy outcomes
4	Agent-identity / delegation-provenance passport	Reconstruct human->agent->sub-agent->tool->data lineage; 53% of MCP servers use static keys	Entity/call-chain correlation	Proprietary cross-runtime delegation graph
5	Cascading-failure circuit breaker (ASI08)	Correlated error/permission/latency propagation across agent graphs	Graph anomaly ranking	Minimal-cut containment with signed delegation evidence
6	Pre-deployment adversarial sandbox	Teams deploy agents without knowing their ASI-Top-10 exposure	Adversarial LLM generating novel attacks	Proprietary agent-vulnerability dataset

Items #1 and #2 are the highest-leverage and lowest-AI-risk, and both compound the neutral-evidence wedge.

17. Hidden Opportunities

- **Ignored segments:** sovereign AI, defense contractors, healthcare agent workflows, financial delegated-payment agents, industrial/robotic agents, and — above all — vendors escaping acquired security platforms.
- **Regulatory tailwind:** as EU AI Act Article 50 transparency bites (Aug 2, 2026) and high-risk obligations land 2027-28, portable machine-verifiable attestation of agent behavior is exactly what auditors will demand. Sentinel is early to the right problem, on the wrong chain and with the wrong GTM.
- **Standards capture:** open-source the evidence verifier + schema to become the "OTel of agent accountability," so incumbents' audit exports terminate in Sentinel — infrastructure, not another guard.
- **Insurer/auditor channel:** evidence packages accepted by insurers and auditors create a distribution path the platforms don't own.

18. Patent-Worthy Ideas

Screened for genuine novelty (ordinary Merkle anchoring is prior art and not defensible):

1. **Vendor-neutral, offline-verifiable evidence-package format** with authenticated provenance — a method claim around hash-chain + inclusion-proof + revocation + customer-held-key verification for *agent* actions.
2. **Federated injection-marker telemetry** — turning per-deployment sanitizer neutralizations into a privacy-preserving cross-customer corpus (behavioral fingerprints) that improves detection without sharing raw prompts.
3. **Minimal-cut cascade containment** — freezing the smallest affected capability subtree using signed delegation evidence, for ASI08 without global kill switches.
4. **Zero-knowledge compliance attestation** — proving agent-behavior compliance to a regulator without exposing proprietary prompts/data (Gemini's hybrid hash-chain + ZK direction).

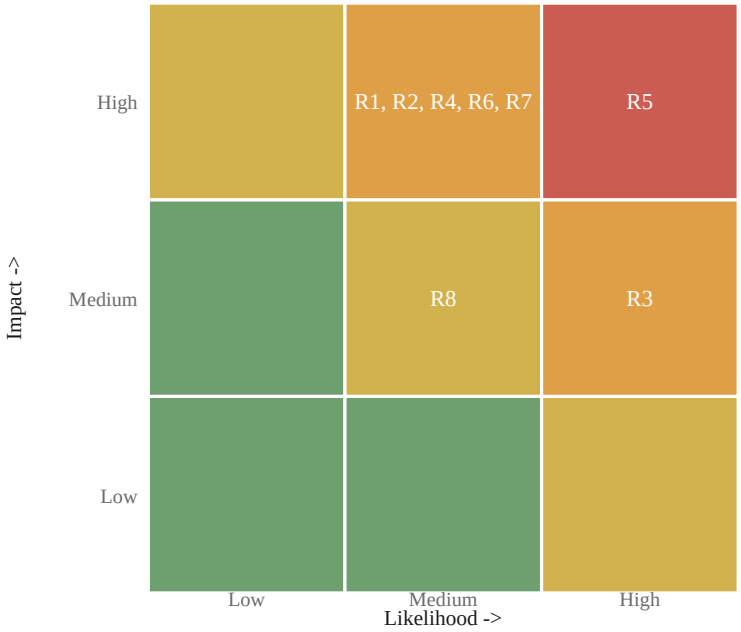
19. Launch Readiness Checklist

Can Sentinel launch today? — Unanimous NO.

Priority	Blocker	Why it blocks	Fix effort
Critical	DLQ bypass / unfenced side effects	Transient outages permanently drop incidents; lease loss duplicates ledger/attestation/approvals	4-8 wks
Critical	Stored XSS on ingested payload	Analyst-side code execution from the attack strings the tool ingests	3-7 days
Critical	Reject route returns 500	Core analyst workflow is unusable	Hours
Critical	Forgeable evidence package	The headline non-repudiation claim fails	4-8 wks + crypto review
Critical	No RLS (app-only tenancy)	One future missing predicate -> cross-tenant breach	3-5 wks
Critical	Immutable unredacted payload storage	GDPR / CSAM liability	4 wks
High	OIDC unwired (SSO is dead code)	Enterprise procurement fails on SSO	2-3 wks
High	Structural tests partly theatre	False assurance; risks relocation #6	2-4 wks
High	Detector unusable / mandatory LLM	Cannot rank alerts; cost/latency/DoS	reframe + 6-12 mo data
Medium	Per-worker rate limits; no batching; no OTel ingest	Scale & cost ceilings	2-4 mo
Low	Base Sepolia branding; dead UI; reproducibility	Reads hackathon-grade	2-4 wks

20. Risk Register

Company Risk Heatmap (Likelihood x Impact)



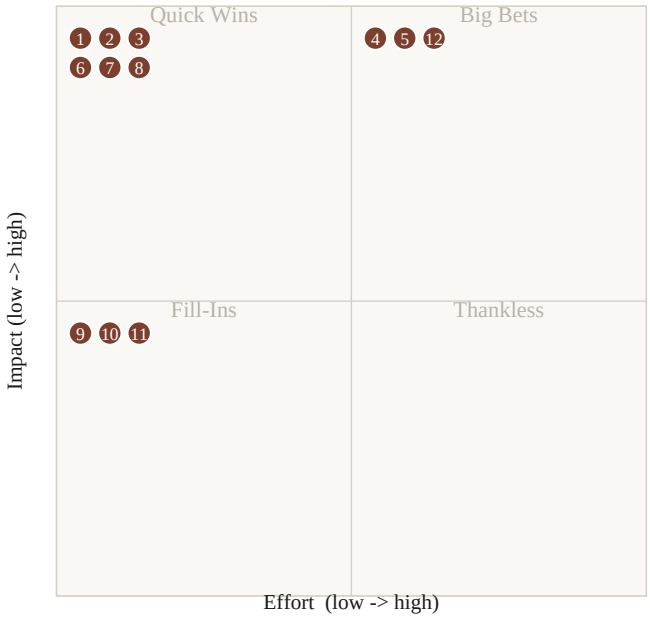
R1	Sixth relocation of the same failure class
R2	Evidence inconsistent exactly during failures
R3	Detector never reaches usable calibration
R4	Platform giants bundle the wedge away
R5	Stranded buyers reject after first pentest
R6	GDPR/CSAM liability from immutable payloads
R7	No design partners convert to paid
R8	Team-bet thesis fails without product proof

ID	Risk	Mitigation
R1	Correctness theater outpaces real enforcement	Mutation tests; PostgreSQL concurrency tests; external review
R2	Trust evidence forks/forges under failure	Authenticated provenance; per-tenant transactional append; customer-held keys
R3	Detection stays uncalibrated	Demote to shadow; deterministic policy authoritative; BYO-detector
R4	Incumbents absorb the wedge	Win neutrality + standard adoption because Sentinel competes with none
R5	Diligence rejection	Close all Criticals before any pentest-exposed pilot
R6	Compliance liability	Pre-ledger redaction + tombstone pattern
R7	No paid conversion	3-5 paid design partners at $25k-$75k as the proof gate

21. Prioritized Improvement Backlog

Scored by Impact vs Effort (RICE-style; MoSCoW tags in the table). Quick Wins first, Big Bets funded deliberately.

Improvement Backlog - Impact vs Effort



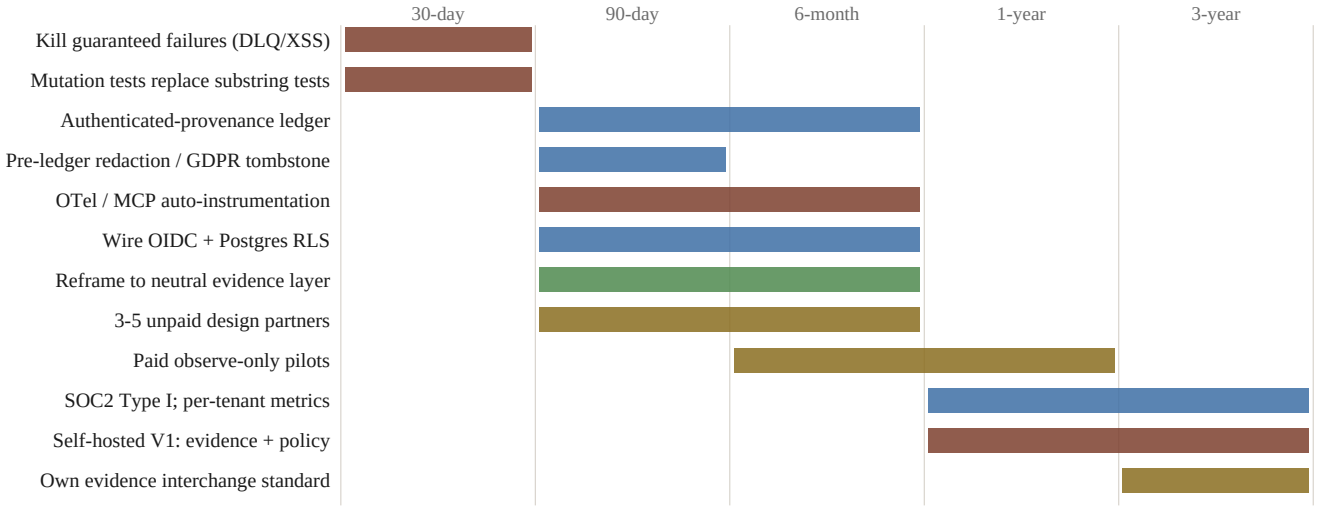
1	Fix reject-500
2	Fix stored XSS + CSP
3	Convert theatrical tests to mutation tests
4	DLQ bypass + fence all side effects
5	Re-anchor evidence provenance
6	Wire OIDC + Postgres RLS
7	OTel auto-instrumentation
8	Pre-ledger redaction / GDPR tombstone
9	Reframe - BYO-detector, demote ML
10	Distributed rate limiting + cost ceiling
11	Remove Base Sepolia default framing
12	Authenticated SPA + approval workflow

#	Item	MoSCoW	Priority
1	Fix reject-500	Must	**Critical**
2	Fix stored XSS + CSP	Must	**Critical**
3	Mutation tests for load-bearing invariants	Must	**High**
4	DLQ + end-to-end fencing	Must	**Critical**
5	Authenticated evidence provenance	Must	**Critical**
6	OIDC wiring + RLS	Must	**Critical**
7	OTel auto-instrumentation	Should	**High**

#	Item	MoSCoW	Priority
8	Pre-ledger redaction	Must	**Critical**
9	BYO-detector reframe	Should	**High**
12	Authenticated SPA + approvals	Should	**High**

22. Multi-Year Product Roadmap

Sentinel Roadmap - Engineering, AI, Security, Business tracks



Eng	track: Eng
Sec	track: Sec
AI	track: AI
Biz	track: Biz

- **30-day:** close both Criticals (DLQ/fencing, XSS+reject), convert headline structural tests to mutation tests, wire-or-delete OIDC. Stop shipping guaranteed failures.
- **90-day:** reframe to the vendor-neutral evidence layer; ship OTel auto-instrumentation + authenticated-provenance ledger; sign 2-3 unpaid design partners on real traffic.
- **6-month:** RLS + one paid regulated pilot; replace testnet framing with periodic Merkle anchoring to customer-controlled roots; publish per-tenant precision/recall at real base rates; external security review.
- **1-year:** 3-5 paying customers on the evidence/portability wedge; calibrated BYO-detector story; SOC2 Type I in progress — a Series A *conversation*, not a check.
- **3-year:** own the open agent-evidence interchange standard so incumbents' audit exports terminate in Sentinel — infrastructure, not another guard.

23. Final Council Consensus

Consensus scorecard (per seat -> mean)

Dimension	Claude	Codex	Gemini 3.1 Pro	Consensus
Overall	34	31	42	**36**
Engineering	58	54	55	**56**
AI / ML	30	24	25	**26**
UX	24	15	20	**20**
Architecture	55	46	65	**55**
Innovation	43	42	50	**45**
Security	42	31	35	**36**
Scalability	36	28	45	**36**
Business	22	25	60	**36**
Investment	20	14	25	**20**

Consensus votes

Question	Claude	Codex	Gemini	Consensus
Can launch today?	NO	NO	NO	**NO (unanimous)**
Safe to run a real pilot?	NO	NO	NO	**NO (unanimous)**
Viable commercial product?	NO	NO	NO	**NO (unanimous)**
Fundable at seed?	NO	NO	YES*	**NO (2-1; *pivot only)**
Fundable at Series A?	NO	NO	NO	**NO (unanimous)**
Defensible moat today?	NO	NO	NO	**NO (unanimous)**
Category-defining potential?	NO**	YES	YES	**YES, conditional on the pivot**

\ *Gemini's seed YES is explicitly "only as a pivot to a vendor-neutral observability layer."* * Claude's NO is "not on this code" — it agrees the potential exists via the pivot.

Biggest single risk, per seat

- **Claude:** failure classes relocate a sixth time; correctness theater outpaces real enforcement.
- **Codex:** the trust evidence becomes inconsistent precisely during the failures customers need it to prove.
- **Gemini:** immutable storage of unredacted attacker payloads creates fatal GDPR/CSAM liabilities.

The verdict

Sentinel is **not** launchable, commercially viable, or fundable as an AI-security detection product today. It **is** a disciplined engineering substrate and an honest team sitting on a real, timely, potentially category-defining opportunity — the neutral, verifiable evidence-and-policy layer for the agent era — which the current code does not yet earn. **Recommendation: a small, note-only team bet, contingent on the pivot and on closing every Critical defect before a single pentest-exposed pilot.**

24. Actionable Next Steps

This week (days, not weeks):

1. Pass `body.reason` to fix the reject-500; add a route test.
2. Replace `innerHTML` with `textContent` + strict CSP; add a browser security test.
3. Remove the Base Sepolia default framing from the dashboard header.

Next 30 days:

1. Fix the DLQ bypass: typed retryable/terminal outcomes; only `repository.fail()` on terminal policy errors.
2. Thread the lease epoch through the pipeline; gate every side-effecting write on it (idempotent outbox for attestations/approvals/webhooks).
3. Convert the two substring "structural" tests to mutation tests that fail when a predicate is removed or a transaction split.
4. Wire OIDC as a real bearer dependency, or delete it and re-scope the SSO claim.

Next 90 days:

1. Re-anchor the evidence moat: signed batch manifests + customer-held keys + independently published roots; `UNIQUE(tenant_id, prev_chain_hash)` or single-writer sealing.
2. Ship OTel/LangChain/MCP auto-instrumentation to kill the manual-SDK adoption wall.
3. Add Postgres RLS + pre-ledger redaction (GDPR tombstone).
4. Reframe the product and API to bring-your-own-detector; demote the ML model to a shadow signal.
5. Sign 2-3 unpaid design partners on real agent traffic, observe-only.

The one-sentence mandate: stop selling a detector and a blockchain; become the neutral flight-data-recorder for AI agents that every runtime and every incumbent writes to — and earn it by making the evidence trustworthy before anyone relies on it.

Prepared by the AI Product Review Board — Claude Opus 4.8, OpenAI Codex (GPT-5.6-sol), and Antigravity / Gemini 3.1 Pro — via three adversarial rounds over the live repository. Scores are each model's independent judgment; consensus figures are unweighted means. Code claims cite `file:line`*; several were verified by reading only (the managed environment denied test execution) and are flagged as such in the full round transcripts under* `council/transcript/`*. This is diligence opinion, not financial advice.*